Privacy and Cybersecurity Client Research Cases

A junior consultant briefing exercise

You are a junior consultant. Before the client meeting, your team must brief a senior consultant on one real privacy or cybersecurity case. Use public evidence to explain the issue, identify the relevant rules or institutions, and recommend what the senior consultant should ask or do next.

How to work

- Work in a team. Each team takes one case. Use the supplied sources as starting points, then find at least one additional reliable source.
- Prepare a 2-minute oral briefing and a short written note. Your audience is a senior consultant who must lead a client conversation, not a lawyer who needs a full legal opinion.
- Cite the exact source for each important claim. Label each point as a verified fact, your interpretation, or an open question.
- If public sources do not establish an answer, say “we could not verify this from public sources” and explain what evidence you would request from the client.

A useful briefing structure

- Issue: What decision or risk is the client facing?
- Evidence: What happened or what does the provider publicly promise? Give dates and cite sources.
- Rule and actors: Which law, regulator, company entity, EU body, or international actor matters?
- Assessment: What follows from the evidence? What remains uncertain? Separate legal scope from compliance.
- Next steps: Give two practical recommendations and three questions to ask the client.

Research standards

Do not treat a company statement as independent verification. Do not treat a regulator’s allegation as a final finding unless the source says it is final. A law applying to an organization does not by itself prove that the organization complied with it. Check whether later decisions, appeals, amendments, or implementation steps changed the position.

SUGGESTED CLASS FORMAT

About 20 minutes of research, 2 minutes per team to brief, and 1 minute of questions from the senior-consultant role. The instructor can assign cases to teams or let teams choose.

CASE 1 | RESEARCH AND PREPARE A CLIENT BRIEFING

Microsoft EU Data Boundary

Focus: Data location, transfers, vendor assurance

Client situation

A European organization is considering Microsoft 365 or Azure for sensitive customer information. The procurement team has seen Microsoft's EU Data Boundary materials and asks whether choosing an EU region means personal data stays in Europe and the organization has "solved GDPR." You are asked to prepare the evidence and questions for the client meeting.

Research questions

1. What services and types of data does Microsoft say are covered by the EU Data Boundary? What does the documentation say about configuration and customer responsibility?
2. Identify at least two stated circumstances in which data, remote access, or security operations can cross the boundary. How does Microsoft describe safeguards for those cases?
3. Under GDPR, what is the difference between data residency, an international transfer, and overall compliance? Which GDPR provisions should the senior consultant check?
4. What facts about the client's tenant, service configuration, data, contract, and Microsoft roles would you need before reaching a conclusion?
5. Draft three questions for the client and one measured recommendation. Avoid concluding that the service is automatically compliant or non-compliant.

Your assignment to the senior team

Tell the senior consultant what the public documentation supports, what it does not settle, and what procurement evidence to request (for example, service configuration, data processing terms, transfer documentation, and the client's risk assessment).

Start with these sources

- Microsoft: What is the EU Data Boundary? - Provider documentation; check its publication/update date.
- Microsoft: Continuing data transfers for all services - Provider documentation on ongoing exceptions and safeguards.
- GDPR, Regulation (EU) 2016/679 - Check Articles 3, 28, 32 and Chapter V on transfers.

Then locate one more reliable source. Prefer the law, regulator, company documentation, or a reputable technical investigation. Record the date and the exact page or paragraph you used.

CASE 2 | RESEARCH AND PREPARE A CLIENT BRIEFING

Meta and EU to US data transfers

Focus: GDPR Chapter V, regulators and cross-border cooperation

Client situation

A client asks whether an EU-based service provider can send personal data to a US group company using standard contractual clauses. The senior consultant wants a concrete precedent. Research the Irish Data Protection Commission's 2023 decision concerning Meta Platforms Ireland's Facebook service, including the EU-wide cooperation process and the later EU-US Data Privacy Framework.

Research questions

1. What transfers and legal mechanism did the DPC examine, and what did it find about the safeguards in that case?

2. How did the GDPR cooperation process involve other EU/EEA supervisory authorities and the EDPB? What role did the Article 65 dispute-resolution process play?

3. What corrective measures and fine did the final DPC decision impose? Check the source for appeal status and any later legal or framework developments.

4. Why does this case not mean that every transfer to the United States is automatically unlawful? Explain the difference between GDPR territorial scope and transfer rules.

5. What should the senior consultant ask a client to establish about its exporter, importer, transfer route, legal mechanism, supplementary measures, and data involved?

Your assignment to the senior team

Prepare a short timeline from investigation to final decision. Advise the senior consultant how to use the precedent without assuming the client has the same facts or transfer mechanism.

Start with these sources

- Irish Data Protection Commission: Meta Facebook transfer decision - Final decision and process summary.
- EDPB: Binding decision 1/2023 - Board decision in the dispute-resolution process.
- European Commission: EU-US Data Privacy Framework adequacy decision - Later framework development; assess what it changes and what it does not.

Then locate one more reliable source. Prefer the law, regulator, company documentation, or a reputable technical investigation. Record the date and the exact page or paragraph you used.

CASE 3 | RESEARCH AND PREPARE A CLIENT BRIEFING

British Airways and the 2018 payment data breach

Focus: Security controls, breach response and regulator findings

Client situation

A travel company asks what a published GDPR enforcement case can teach it about security governance. Use the UK Information Commissioner's final penalty notice concerning British Airways' 2018 attack. The incident occurred while the UK was an EU Member State; the regulator issued its final notice in 2020.

Research questions

1. According to the final notice, how did the attacker gain access and what happened to customer payment data? Give the incident period and affected data types stated in the source.

2. Which GDPR security provisions did the ICO find had been infringed? What control weaknesses did it identify?

3. What did the ICO say about BA's notification and cooperation? What final penalty was imposed, and how did it differ from the initially proposed penalty?

4. Separate the regulator's findings from your own general security recommendations. Which recommendations are supported by this case, and which would need other evidence?

5. Prepare three discovery questions for a client about access control, monitoring, web application changes, incident response, and evidence of control effectiveness.

Your assignment to the senior team

Give a concise account of the attack, the regulator's findings, and the limits of using one historic enforcement case to assess a different company. Recommend what evidence to request before judging the client's security.

Start with these sources

- UK ICO: British Airways penalty notice (PDF) - Primary source; read the summary, findings, and penalty sections.
- UK ICO: Personal data breaches guidance - Use for current breach reporting concepts; distinguish guidance from the historical decision.
- GDPR, Regulation (EU) 2016/679 - Check Articles 5(1)(f), 32 and 33.

Then locate one more reliable source. Prefer the law, regulator, company documentation, or a reputable technical investigation. Record the date and the exact page or paragraph you used.

CASE 4 | RESEARCH AND PREPARE A CLIENT BRIEFING

Amazon Web Services and NIS2 scope

Focus: Cloud services, entity size, national implementation

Client situation

An EU-based client uses AWS for business-critical workloads and asks whether its cloud provider is covered by NIS2, what that means for the client, and who supervises the provider. Use AWS as the real provider under review. Public product pages alone may not identify the precise legal entity, service, size category, or competent authority relevant to the client's arrangement.

Research questions

1. Does NIS2 name cloud computing service providers? Find the definition and the relevant Annex I sector. What size and territorial conditions appear in the Directive?
2. What obligations does NIS2 place on covered essential and important entities, and what is the basic incident-reporting timetable? Cite the specific provisions.
3. Which AWS legal entity and service appear in the client's contract or public terms? What additional evidence would be needed to determine whether a particular entity is in scope and which Member State is responsible?
4. Does a provider's possible NIS2 coverage remove the client's own security or supplier-management responsibilities? Identify relevant NIS2 provisions and explain the limits of your conclusion.
5. Check the implementation status in the client's Member State and any later amendments or Commission rules. What should the senior consultant verify with local counsel or the competent authority?

Your assignment to the senior team

Prepare a conditional assessment: list what the Directive clearly says, what you can verify about the provider arrangement, and what remains unresolved. Tell the senior consultant which contract, service, entity, Member State and authority details to confirm.

Start with these sources

- NIS2 Directive (EU) 2022/2555, EUR-Lex - Check Articles 2, 3, 20-23, 26 and Annex I.
- European Commission: NIS2 Directive overview - Context and implementation information; verify current status.
- Commission Implementing Regulation (EU) 2024/2690 - Technical and methodological requirements for specified digital providers, including cloud providers.
- AWS: Legal and contractual information - Locate the contract entity and service documents relevant to the client; do not infer these from the brand name alone.

Then locate one more reliable source. Prefer the law, regulator, company documentation, or a reputable technical investigation. Record the date and the exact page or paragraph you used.

CASE 5 | RESEARCH AND PREPARE A CLIENT BRIEFING

Viasat KA-SAT and the EU cyber diplomacy response

Focus: Incident impact, public attribution and international response

Client situation

A client with satellite-dependent operations asks how a cyber incident can become a cross-border political and security issue. Research the 24 February 2022 attack on Viasat's KA-SAT network and the EU's public declaration of 10 May 2022. Keep technical incident reporting separate from political attribution.

Research questions

1. What does Viasat's incident report say happened technically, how did it affect service, and what recovery actions were described?
2. What did the EU declaration attribute to whom, when was it issued, and what cross-border impacts did it describe?
3. Which actors appear in the response: the affected company, national authorities, the EU High Representative/Council, EU Member States, NATO or other partners? Verify each role rather than assuming all organizations acted in the same way.
4. What diplomatic tools are visible in the EU response (for example, public attribution, condemnation, solidarity, or a statement of expected state behaviour)? What does the declaration say about possible further steps?
5. What should the senior consultant advise a satellite-dependent client to ask about resilience, incident communications, alternative connectivity, supplier dependencies, and cross-border reporting?

Your assignment to the senior team

Brief the senior consultant on the documented technical impact and the EU's political response. State whose attribution it is and what public evidence you found; do not present attribution as a technical fact independently proven by the company report.

Start with these sources

- Viasat: KA-SAT network cyber attack overview - Company technical account; identify its perspective and limits.
- UK National Cyber Security Centre: Public attribution and allied assessment - Compare the UK assessment with the EU statement.
- Council of the EU: Declaration on the KA-SAT attack - EU public attribution and diplomatic response.
- EU Cyber Diplomacy Toolbox - Use to connect the case to the EU's broader response framework; verify which measures were actually used in this case.

Then locate one more reliable source. Prefer the law, regulator, company documentation, or a reputable technical investigation. Record the date and the exact page or paragraph you used.

TEAM WORKSHEET | COMPLETE BEFORE THE CLIENT MEETING

Senior consultant briefing note

Case number and title: _____

Team members: _____

1 The issue

In one sentence, what decision or risk is the client facing?

_____

2 What we verified

List two or three evidence-backed facts. Add source and date beside each.

_____

_____

3 The rule and the actors

Name the relevant law or framework, regulator or institution, and company entity if known.

_____

_____

4 Our assessment

What is your best-supported interpretation? What remains unknown from public sources?

_____

_____

5 Recommendation

Give two practical next steps for the client or senior consultant.

_____

_____

6 Questions for the client

Write three questions that could change your assessment.

_____

_____

_____

7 Sources

List the sources you used and the claim each one supports.

_____

_____

INSTRUCTOR OR PEER REVIEW

What makes a useful briefing

Accurate: The team distinguishes facts in primary sources from interpretation and does not overstate legal conclusions.

Specific: The briefing names the relevant company entity, service, data, time period, legal provision, and authority where the evidence allows.

Balanced: The team includes evidence that qualifies or limits its conclusion, and checks later developments where relevant.

Useful to the client meeting: The recommendation is actionable and the questions are designed to uncover facts that public sources cannot provide.

Quick feedback

Strongest evidence: _____

Most important uncertainty: _____

One question to take into the client meeting: _____